SW30LABS · JULY 2026

DriftLab

Prove what your agents actually do.

Continuous, machine-readable compliance for running agentic systems — behavioral drift detection against certified OSCAL baselines, with **experimental proof**.

local-first | deterministic | OSCAL-native | EU AI Act · SOC 2 · ISO 42001

PROBLEM

Agents drifted. Nobody can prove it.

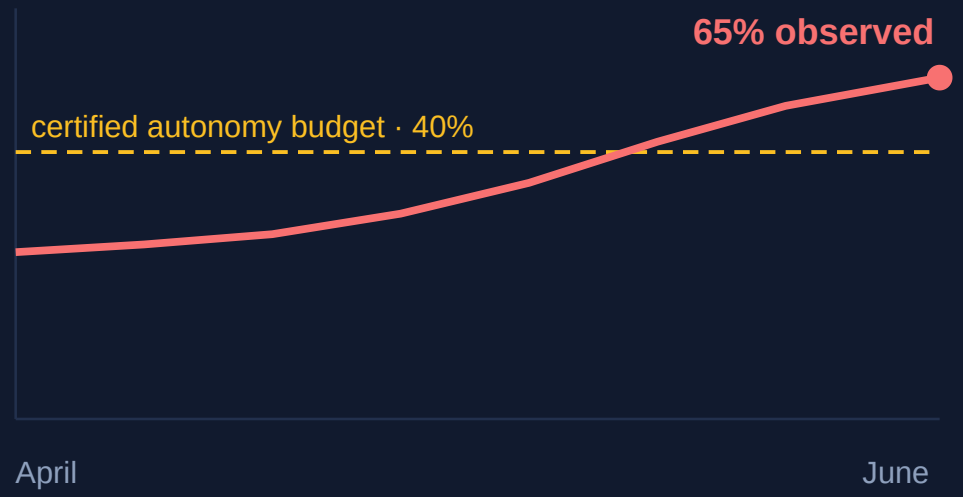
Enterprises are pushing autonomous agents into **regulated decisions** — credit, claims, support, treasury.

The governance stack never left the design phase:

- Policy documents & governance canvases — written once
- Model risk registries — inventories, not behavior
- Build-time graph diffs — structure, not runtime

The question a regulator actually asks — "did the agent route high-value decisions past the human gate last quarter?" — is **unanswerable with evidence** today.

A quarter of real agent behavior:



Silent autonomy creep: no incident, no alert, no evidence trail — until the audit.

WHY NOW

The compliance clock is running.

2 Dec 2027

EU AI Act high-risk (Annex III) obligations — credit scoring, hiring, education. Digital Omnibus (June 2026) fixed the runway; Art. 9 demands continuous risk management, Art. 14 demonstrable human oversight.

83%

of Fortune 500 procurement teams plan to require ISO/IEC 42001 alignment from vendors by 2027 (Gartner 2026). Insurers already discount AI liability 15–25% for aligned firms.

~15×

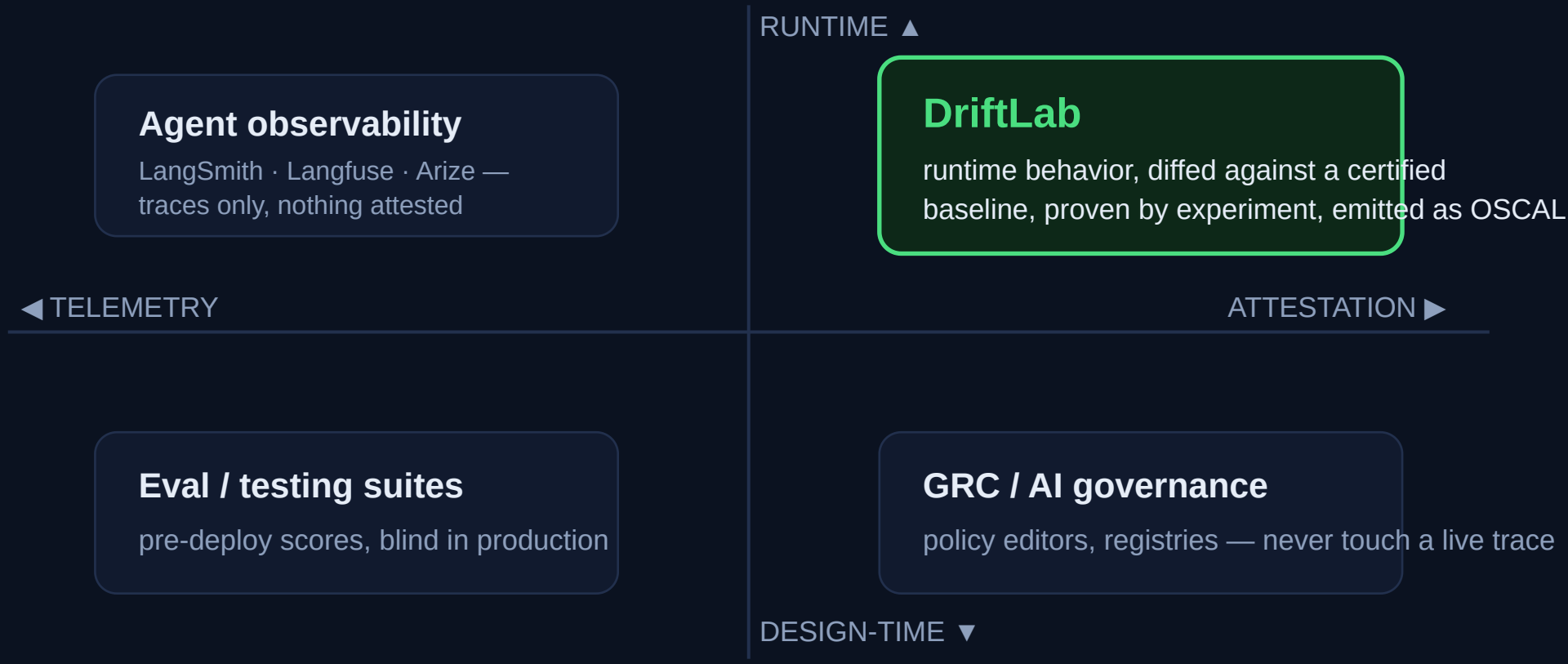
AI-governance spend growth projected: ~$0.4–0.9B (2025) → $6–7B by 2034-35, 23–35% CAGR. Financial services is the dominant segment.

The fastest-growing risk surface — agent runtime behavior — has no shipping control-monitor product.

Sources: Gibson Dunn & Covington on the EU Digital Omnibus (2026) · aigovernancetoday.com · TrendX Insights / Global Insight Services market reports. Details in docs/PITCH.md

MARKET GAP

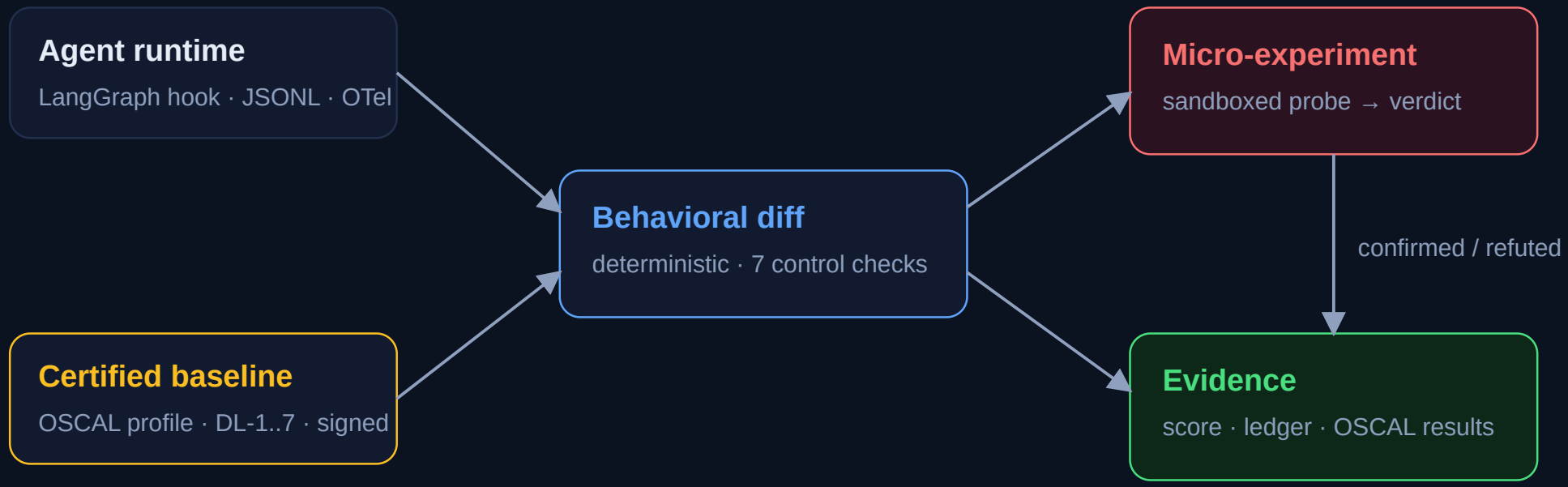
Telemetry isn't attestation. Documents aren't behavior.



Infra drift detection (Terraform) proved this category works. **The agent-behavior quadrant is empty.**

HOW IT WORKS

Certify once. Observe continuously. Prove on demand.



Seven certified controls (DL-1..7): tool decision rights · routing rules · HITL triggers · fallback protocols · critical sinks · autonomy budget · required steps — each crosswalked to SP 800-53r5, anchored on **CA-7 continuous monitoring**. A staleness-weighted monitor runs the estate on cron/launchd.

THE DIFFERENTIATOR

Alerts get argued with. Proof doesn't.

Every finding becomes a **falsifiable hypothesis** with a probe spec. A LangGraph loop — design → execute → evaluate → reflect — re-tests it against a **sandboxed replay** of the full matching population.

- **Existence claims** — unauthorized tool, route, HITL bypass: one independently **reproduced violation is proof**; zero across sufficient samples refutes.
- **Rate claims** — autonomy budget: ordered windows must sustain the breach. A one-off burst stays inconclusive.

Verdicts are **computed from probe evidence — never LLM opinion**. Probes are replay-only; isolation is enforced in code and tested with booby-trapped sockets.

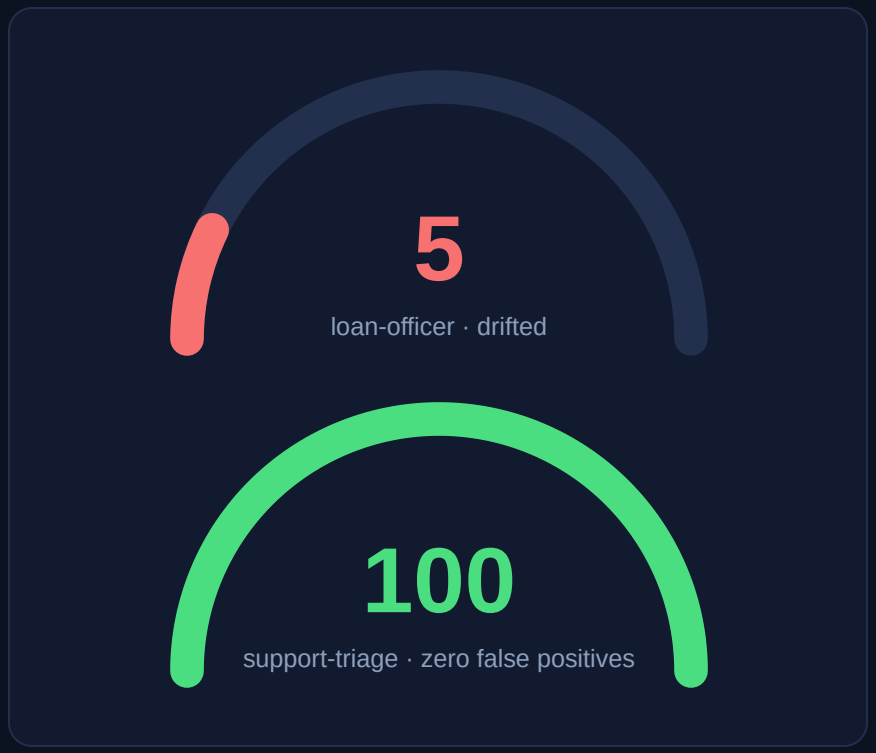
Verdict semantics

VERDICT	MEANING
CONFIRMED	violation reproduced on independent replay — escalate with evidence
REFUTED	did not reproduce — remediation verified, or false alarm caught
INCONCLUSIVE	thin evidence — widen the window, don't cry wolf

Re-testing last cycle's confirmed drift against fresh traces gives you **remediation verification for free**.

LIVE DEMO (SHIPS IN THE REPO)

One drifted agent. Four proofs. Score: 5/100.



All four seeded drifts detected — and experimentally confirmed:

DRIFT	PROBE EVIDENCE
HITL gate bypassed (CRITICAL — reaches funds)	**5/8** high-value runs, rate 0.625
Autonomy 65% vs 40% budget	**3/3** windows sustain breach
Unvetted tool `external_data_broker`	**2** reproduced invocations
Error fallback skipped	**1/2** errors unhandled

`driftlab demo` → detects, scores, proves, and writes the audit evidence in ~4 seconds. **88-test suite, fully offline.**

EVIDENCE

The output is the audit artifact.

Per agent, per cycle:

- **`assessment-results.json`** — OSCAL 1.1.2: observations with trace evidence, per-control `satisfied` / `not-satisfied` findings, experiment verdicts with reproduction counts
- **`assessment-plan.json`** — generated from the certified baseline (CA-7 cadence)
- **`ledger.json`** — deterministic anomaly ledger: same inputs → **byte-identical bytes**. An auditor can re-run the diff.
- **`report.md`** — human-readable summary

Maps onto **EU AI Act Art. 9 / 12 / 14 · ISO 42001 §8 · SOC 2 monitoring criteria**.

```
// cycle finding, loan-officer
"target": { "target-id": "dl-3_smt",
  "status": { "state": "not-satisfied" }}
// linked micro-experiment
"title": "micro-experiment: CONFIRMED — missing_hitl",
"props": [
  { "name": "dl:verdict", "value": "confirmed" },
  { "name": "dl:probe-violations", "value": "5" },
  { "name": "dl:probe-samples", "value": "8" },
  { "name": "dl:sandbox", "value": "replay" }]
// clean agents attest positively
"target-id": "dl-5_smt" → "satisfied"
```

MOAT

Built where SaaS can't follow.

Local-first
Traces never leave the host. Deploys inside bank change-control, air-gapped dashboards included. No SaaS observability vendor can sit here.

Deterministic
Pure-Python compliance path. Byte-identical ledgers, content-derived IDs. Reproducibility is the audit feature.

Experimental proof
The only system that closes the loop from "flagged" to "reproduced." Collapses triage debates into evidence.

OSCAL-native
Output drops into NIST-standard evidence pipelines. First mover on **CA-7 for agent behavior**.

Four of five engines are proven sw30labs systems — **glass-graph** (deterministic diff), **regitel** (staleness monitor), **governance-oscal** (compliance schemas), **setpoint** (experiment pattern). The integration is the product, and it exists today.

COMPETITION

Nobody occupies the intersection.

CAPABILITY	LANGSMITH / LANGFUSE / ARIZE	GRC & AI-GOV PLATFORMS	INFRA DRIFT (TERRAFORM ET AL.)	DRIFTLAB
Sees runtime agent decisions	✔ traces	✖	✖	**✔ canonical events**
Diffs against certified baseline	✖	✖ documents only	✔ for infra	**✔ behavioral, 7 controls**
Proves drift experimentally	✖	✖	✖	**✔ sandboxed probes**
Emits audit-grade OSCAL	✖	partial, manual	✖	**✔ per cycle, CA-7**
Runs fully on-prem / air-gapped	partial	partial	✔	**✔ local-first by design**

Observability players could add attestation — but their architecture (cloud telemetry, no baseline semantics, LLM-scored evals) points the other way. **DriftLab starts where they stop.**

GO-TO-MARKET

Land on one agent. Expand to the estate.

Beachhead — Tier-1/2 financial services running agents in **Annex III workflows**. Credit decisioning is the canonical named high-risk case — and our shipped demo.

Wedge deal — one agent, one certified baseline, one regulator conversation. 90-day pilot; success = an audit finding closed with DriftLab evidence.

Then — insurers, EU-regulated SaaS, government suppliers chasing ISO 42001 procurement requirements.

Business model

MOTION	REVENUE
Self-host license	per monitored estate / yr — a compliance budget line, not tooling
Certification advisory	fixed-fee baseline certification per agent archetype
Audit-as-a-service	evidence packs per assessment window

Compliance spend survives tooling winters.

ROADMAP

From evidence engine to regulatory autopilot.



v2: estate intelligence — cross-agent drift correlation, drift-to-change attribution, one-click evidence packs.
v3: EU AI Act / ISO 42001 text auto-mapped to DL-control parameterizations; continuous authorization with drift SLOs.

THE ASK

2–3 design partners. 90 days each.

Regulated teams running agents in production. Success is binary: **one audit finding closed with DriftLab evidence.**

Nicolas Cravino · sw30labs · ncravino@mac.com

`github: sw30labs/driftlab` — working demo: `uv run driftlab demo`

deterministic compliance path | traces never leave the host | verdicts from evidence, never LLM opinion